

Отчет по результатам аудита безопасности

Minecraft Sports League

1. Обзор

В ходе анализа безопасности серверной инфраструктуры проекта были выявлены критические узлы, требующие немедленной настройки. Основная задача – скрыть технические детали архитектуры от внешней сети и ограничить доступ к серверу только через доверенные узлы (прокси-серверы).

2. Выявленные уязвимости и риски

2.1. Утечка реального IP-адреса. Через обратные DNS-записи (PTR) в публичном доступе любой пользователь может вычислить реальный IP-адрес хоста, скрытый за прокси-сервером.

Риск: DDoS-атака пойдет в обход защиты напрямую на сервер, что приведет к его недоступности.

2.2. Открытый доступ к службе мониторинга Zabbix. Программа доступна для входящих соединений из внешней сети.

Риск: Сбор данных о нагрузке и конфигурации сервера, а при наличии уязвимостей в версии Zabbix – риск RCE на хосте.

2.3. Избыточная техническая информация (Nginx): Сервер открыто выдает версии ПО и метаданные хостинга.

Риск: Упрощение процесса разведки (reconnaissance) при подготовке атаки.

2.4. Открытый доступ к административной панели. Отсутствие фильтрации входящих соединений.

Риск: Угроза получения несанкционированного доступа к панели управления.

3. План исправлений (Security Hardening)

Для минимизации выявленных рисков рекомендуется принять следующие меры:

Настройка Firewall (UFW):

- Внедрение «белого списка» IP-адресов прокси-серверов (DDoS-Guard).
- Полное закрытие прямого доступа к критическим портам (включая 10050/tcp) для всех, кроме доверенных адресов.

Укрепление безопасности веб-сервера (Nginx Hardening):

- Отключение заголовков сервера (`server_tokens off;`).
- Настройка ограничений доступа к административным панелям через IP-whitelist (ограничение доступа по конкретным IP).